

EVIDÊNCIA TÉCNICA - PROVA DE CONCEITO (PoC)

ALVO: *.techcorp.com

PESQUISADOR: hacker@hunter.com

TIPO DE VULNERABILIDADE: Stored Cross-Site Scripting (XSS)

1. DESCRIÇÃO DA FALHA

Identificada falha de sanitização no endpoint de atualização de perfil corporativo. O parâmetro "descricao" aceita e armazena tags HTML e scripts arbitrários sem realizar qualquer tipo de validação no backend.

2. IMPACTO

Execução silenciosa de código JavaScript no navegador de qualquer usuário que visitar a página do perfil afetado. A falha permite o roubo de tokens de sessão (caso não possuam a flag HttpOnly) e a execução de ações não autorizadas em nome da vítima.

3. PASSOS PARA REPRODUZIR

1. Interceptar o tráfego e enviar uma requisição POST autenticada para o endpoint alvo.
2. Injetar o payload malicioso no campo "descricao" dentro do JSON no corpo da requisição.
3. Acessar a URL pública do perfil manipulado.
4. O script injetado é executado imediatamente no carregamento do DOM da página.

4. REQUISIÇÃO MALICIOSA (PAYLOAD)

```
POST /api/empresa/perfil/atualizar HTTP/1.1
Host: api.techcorp.com
Authorization: Bearer [TOKEN_REDACTED]
Content-Type: application/json

{
  "nome": "TechCorp S.A.",
  "cnpj": "11.111.111/0001-11",
  "setor": "Tecnologia",
  "descricao": "<script>alert(document.cookie)</script>"
}
```

5. SUGESTÃO DE MITIGAÇÃO

Implementar rotinas de sanitização de entrada no backend, rejeitando a inserção de caracteres de controle HTML. Adicionalmente, garantir o uso

de codificação de saída (output encoding) no momento em que os dados forem renderizados no frontend.